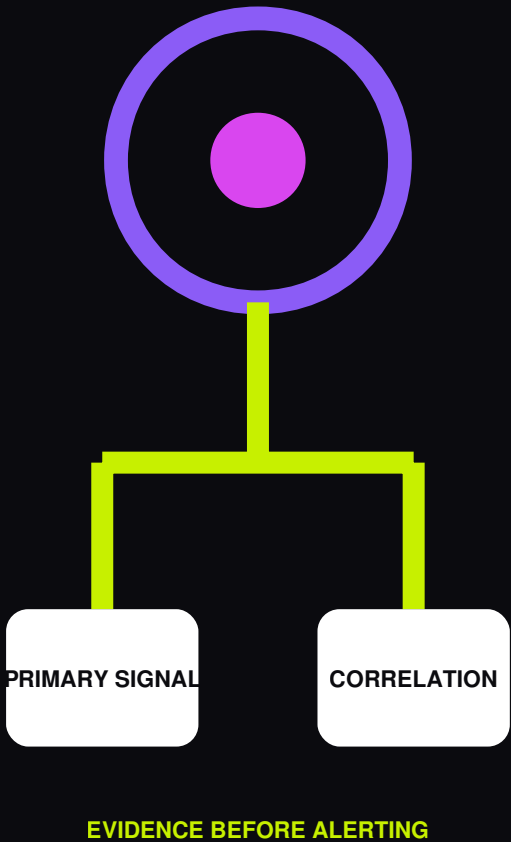


DEVICE CODE TO PYTHON- REQUESTS

Hunts for a successful device-code authentication followed by non-interactive python-requests token use for the same user within the source-supported 10-minute window.

HUNTING QUERY

CONFIDENCE: MEDIUM



REPORT DATE	STATUS
17 September 2026	Untested implementation sketch
PRIMARY PLATFORM	OPERATIONAL VALUE
Microsoft Defender XDR	9.8 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

9.8

Hunts for a successful device-code authentication followed by non-interactive python-requests token use for the same user within the source-supported 10-minute window.

STATUS

Hunting query

Untested implementation sketch; Confidence Medium.

1primary table

0joins

0secondary rules

2validation gates

Evidence boundary

A match is a high-value identity correlation, not proof of GhostCode or compromise. The public evidence does not expose a shared session identifier across both records.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 eSentire published the investigation on 15 September 2026; activity was observed in late August 2026.
- 2 Token use began five seconds after authentication; three devices were registered within 78 seconds.
- 3 The observed backend used python-requests/2.34.2 against Microsoft resources.

Detection hypothesis

If an attacker repeats this behavior, CloudAppEvents should expose the same source-supported identity or content-access pattern. Distinction requires ownership, change, device, sign-in, and approved-automation context.

Unconfirmed elements

A match is a high-value identity correlation, not proof of GhostCode or compromise. The public evidence does not expose a shared session identifier across both records.

Logic: Behavioral correlation + campaign-supported client fingerprint **ATT&CK:** T1528



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

Microsoft Entra diagnostic settings sending sign-in logs to Microsoft Sentinel SigninLogs with AuthenticationProtocol, UserAgent, IsInteractive and UPN populated.

OPTIONAL ENRICHMENT

Conditional Access, AuditLogs, enrolled-device inventory, IP/ASN ownership, account owner and approved device-code workflow inventory.

Fields	Reliability	Use
TimeGenerated, UserPrincipalName, IPAddress	Documented	Query or triage
AuthenticationProtocol, ResultType, UserAgent	Documented	Query or triage
IsInteractive, ResourceDisplayName, CorrelationId	Documented	Query or triage
deviceCode + python-requests behavior	Present in source	Query or triage
IncomingTokenType population	Environment-dependent	Query or triage

Excluded

No message body, phishing-page content, inferred success, actor attribution, or undocumented cross-SIEM mapping is used.



PRIMARY KQL

Direct source-supported conditions with investigable output.

HUNTING

STATUS

Hunting query — Untested implementation sketch

KQL — UNTESTED

```
let D = SigninLogs
| where AuthenticationProtocol == "deviceCode"
| where ResultType == "0"
| project DT=TimeGenerated, UserPrincipalName,
           DIP=IPAddress, DApp=AppDisplayName;
let P = SigninLogs
| where IsInteractive == false
| where UserAgent contains "python-requests"
| project PT=TimeGenerated, UserPrincipalName,
           PIP=IPAddress, ResourceDisplayName,
           IncomingTokenType, ResultType;
D
| join kind=inner P on UserPrincipalName
| where PT >= DT and PT <= DT + 10m
| project DT, PT, UserPrincipalName, DIP, PIP,
           DApp, ResourceDisplayName,
           IncomingTokenType, ResultType
| order by DT desc
```

WINDOW

10m forward

THRESHOLD

None

JOIN

Inner

KEY

UserPrincipalName



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain raw event, entity, timestamps, correlation identifiers and surrounding context.

2

Confirm

Identify the user, device or service owner, origin and approved change record.

3

Enrich

Conditional Access, AuditLogs, enrolled-device inventory, IP/ASN ownership, account owner and approved device-code workflow inventory.

4

Scope

Review adjacent identity, endpoint and network evidence without expanding beyond observed facts.

Expected benign overlap

Authorized device-code workflows followed by Python automation for the same account. Tune only with documented account, owner, resource, egress and change-window context.

Response boundary

A match is a high-value identity correlation, not proof of GhostCode or compromise. The public evidence does not expose a shared session identifier across both records.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

- 1. Confirm SigninLogs ingestion and field population.
- 2. Run a controlled benign device-code flow and separate Python call.
- 3. Measure 30 days of overlap and identify every workflow owner.
- 4. Test whether a shared session key is available before promotion.

Decision criteria

Success: The controlled pair is visible with complete fields and historical matches are attributable.

Rejection: UserAgent is absent or benign overlap cannot be separated.

Failure: Connector missing, retention insufficient, or non-interactive events stored elsewhere.

Platform	Decision	Missing evidence
Defender XDR	Hunting query	Target execution and baseline
Splunk	No reliable implementation	Index, sourcetype, parser, sample
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Hunting query

Hunts for a successful device-code authentication followed by non-interactive python-requests token use for the same user within the source-supported 10-minute window.

A match is a high-value identity correlation, not proof of GhostCode or compromise. The public evidence does not expose a shared session identifier across both records.

MITRE ATT&CK

T1528

References

1. eSentire TRU — GhostCode — 15 Sep 2026
2. Microsoft — SigninLogs schema — accessed 17 Sep 2026
3. Microsoft — OAuth 2.0 device authorization grant flow
4. MITRE ATT&CK — T1528 Steal Application Access Token

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.